

SSH Brute-Force Detection:

Detecting an SSH Brute Force Attack with Wazuh

A self directed project in which I simulated and detected a credential access attack in an isolated virtual lab, using a cloud hosted SIEM for centralized log correlation and MITRE ATT&CK mapped alerting.

Project Overview

In this project, I designed, built, and validated a personal cybersecurity home lab focused on blue team detection engineering. My objective was to construct a realistic, isolated attacker and victim environment, deploy a Security Information and Event Management (SIEM) platform to monitor it, and then prove the detection pipeline works by executing a real attack technique end to end: from adversary action, to log generation, to correlated alert, to compliance and MITRE ATT&CK mapping.

The specific technique I simulated was an SSH password brute force attack (MITRE ATT&CK T1110), launched from an attacker virtual machine against a victim virtual machine, with detection and alerting handled by a Wazuh SIEM I deployed on a separate cloud server.

Lab Architecture

My lab uses a three node design that separates the attack surface from the monitoring infrastructure, mirroring how a real security operations environment separates production systems from the SIEM that watches them.

Host Machine	Windows 11 laptop (Intel i7-1255U, 8 GB RAM) running Oracle VirtualBox
Attacker VM	Kali Linux, used to launch the simulated attack (Hydra)
Victim VM	Ubuntu Server, target of the attack; runs the Wazuh agent and Suricata IDS
SIEM / Manager	Wazuh (manager, indexer, dashboard) deployed on a DigitalOcean cloud VPS
Internal Network	VirtualBox NAT Network (10.0.2.0/24), isolates VM to VM traffic from the host's home network while preserving outbound internet access

Running the SIEM stack on a separate cloud host, rather than locally on the 8 GB laptop, was a deliberate architecture decision I made after the full local Wazuh stack proved too resource intensive for my host's available RAM.

Offloading the manager, indexer, and dashboard to a lightweight cloud VPS let my victim machine run only the small Wazuh agent, keeping the local lab within hardware constraints while still producing a fully functional detection pipeline.

Objective

- Build an isolated, self contained lab environment safe to attack without risk to my host machine or home network.
- Deploy a centralized SIEM capable of ingesting logs from the victim machine and applying correlation rules.
- Validate detection at two levels of severity: a single failed login (baseline) and an automated brute force burst (escalated).
- Map the resulting detection to the MITRE ATT&CK framework and relevant compliance controls (PCI DSS, GDPR, HIPAA, NIST 800-53).

Methodology

1. Baseline Validation

Before running any attack, I confirmed the Wazuh agent on the victim machine was active and reporting to the manager. A review of the Threat Hunting dashboard confirmed my pipeline was live end to end: 330 events had already been logged over 24 hours, correctly attributed to the victim agent and pre tagged with MITRE technique data from normal administrative activity (valid logins, sudo usage).

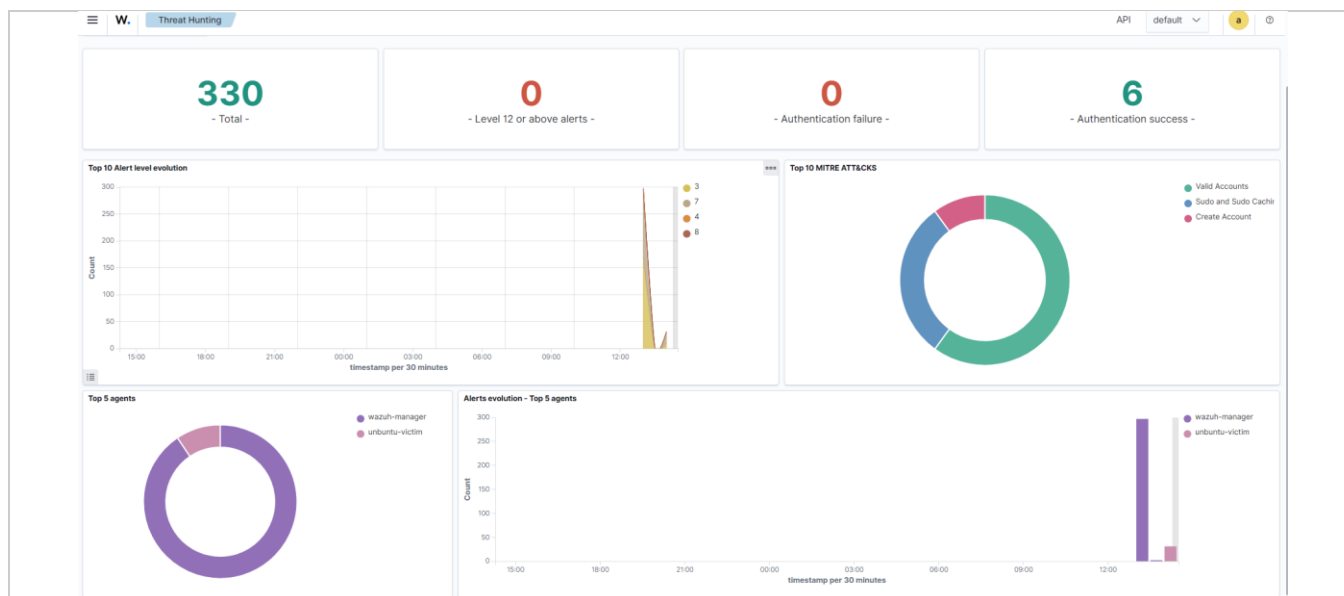


Figure 1: Wazuh Overview dashboard confirming the agent is active and ingesting real event data.

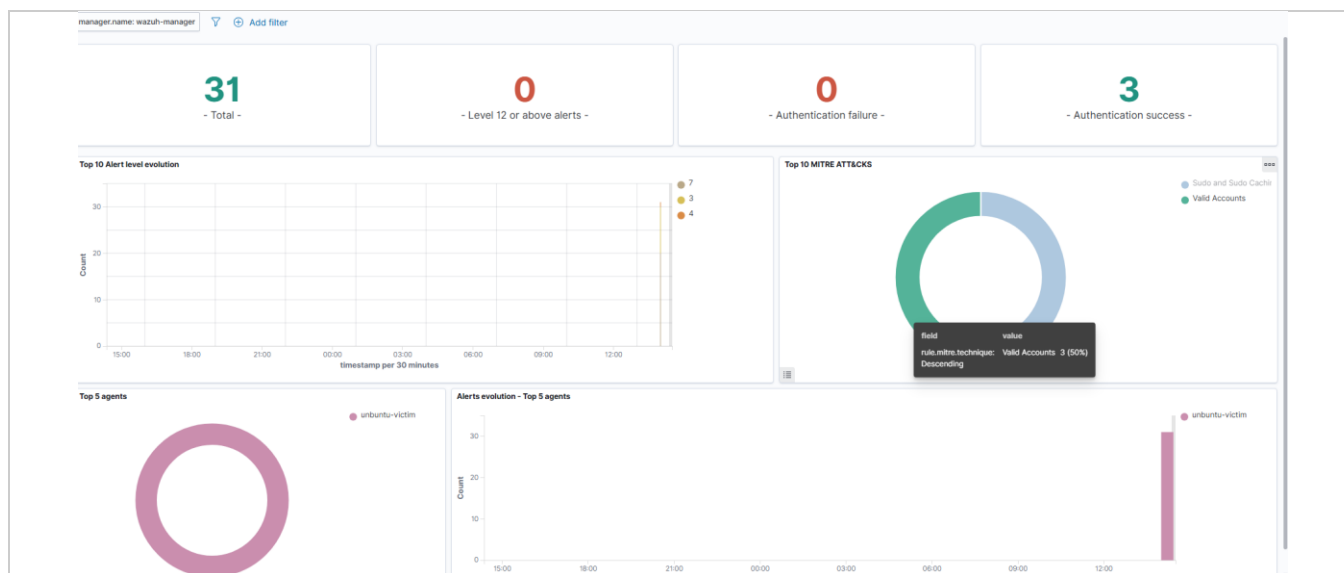


Figure 2: Event data isolated to the victim agent, with automatic MITRE ATT&CK technique tagging visible on baseline activity.

2. Manual Detection Test

I performed a single deliberate failed SSH login against the victim machine to confirm that a discrete, known action would be captured and correctly attributed. The test produced three independently logged events from three different subsystems (sshd, PAM, and unix_chkpwd), all correctly scored at severity level 5, confirming defense in depth logging across the authentication stack.

36 hits					
Sep 3, 2026 @ 14:38:44.095 - Sep 4, 2026 @ 14:38:44.095					
Export Formatted Reset view 639 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Sep 4, 2026 @ 14:38:18.301	ubuntu-victim	PAM: User login failed.	5	5503	
Sep 4, 2026 @ 14:38:18.298	ubuntu-victim	unix_chkpwd: Password...	5	5557	
Sep 4, 2026 @ 14:37:03.875	ubuntu-victim	sshd: authentication fail...	5	5760	
Sep 4, 2026 @ 14:37:01.862	ubuntu-victim	PAM: User login failed.	5	5503	
Sep 4, 2026 @ 14:37:01.828	ubuntu-victim	unix_chkpwd: Password...	5	5557	
Sep 4, 2026 @ 14:07:39.376	ubuntu-victim	PAM: Login session clos...	3	5502	
Sep 4, 2026 @ 14:07:39.365	ubuntu-victim	Successful sudo to ROO...	3	5402	
Sep 4, 2026 @ 14:07:39.360	ubuntu-victim	PAM: Login session ope...	3	5501	
Sep 4, 2026 @ 14:06:10.767	ubuntu-victim	Host-based anomaly de...	7	510	
Sep 4, 2026 @ 14:06:06.968	ubuntu-victim	Host-based anomaly de...	7	510	
Sep 4, 2026 @ 14:06:04.181	ubuntu-victim	PAM: Login session clos...	3	5502	

Figure 3: A single failed login attempt captured independently by sshd, PAM, and unix_chkpwd.

3. Automated Attack Simulation

With baseline detection confirmed, I launched an automated brute force attack from the Kali attacker VM using Hydra, targeting the victim machine's SSH service with a standard password wordlist (rockyou.txt).

```

kaliuserattk@mankali-attacker: ~
$ ls -lh /usr/share/wordlists/rockyou.txt
-rw-r--r-- 1 root root 134M May  7 05:16 /usr/share/wordlists/rockyou.txt

kaliuserattk@mankali-attacker: ~
$ hydra -l ubuntuvictim -P /usr/share/wordlists/rockyou.txt ssh://10.0.2.3
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-09 11:38:22
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://10.0.2.3:22/
[ERROR] all children were disabled due to too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
The session file ./hydra.restore was written. Type "hydra -R" to resume session.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-09 11:39:07

kaliuserattk@mankali-attacker: ~
$ ss

```

Figure 4: Hydra launched from the attacker VM against the victim's SSH service.

The attack generated a rapid burst of failed authentication attempts from a single source IP within a short time window, exactly the pattern a brute force detection rule is designed to catch.

4. Detection & Escalation

The resulting event log showed a clear escalation pattern. Individual failed logins were logged at severity level 5, as expected, but once the volume and timing threshold was met, Wazuh's correlation engine fired a distinct, higher severity alert: "Multiple authentication failures" (Rule ID 40111, severity level 10).

timestamp	agent.name	rule.description	rule.level	rule.id
Sep 9, 2026 @ 11:42:04.598	ubuntu-victim	Log file rotated.	3	591
Sep 9, 2026 @ 11:39:05.794	ubuntu-victim	Multiple authentication failures.	10	40111
Sep 9, 2026 @ 11:39:05.792	ubuntu-victim	Maximum authentication attempts exceeded.	8	5758
Sep 9, 2026 @ 11:39:05.792	ubuntu-victim	syslog: User authentication failure.	5	2501
Sep 9, 2026 @ 11:39:05.781	ubuntu-victim	sshd: authentication failed.	5	5760
Sep 9, 2026 @ 11:39:05.757	ubuntu-victim	syslog: User missed the password more than o...	10	2502
Sep 9, 2026 @ 11:39:05.752	ubuntu-victim	syslog: User authentication failure.	5	2501
Sep 9, 2026 @ 11:39:05.748	ubuntu-victim	Maximum authentication attempts exceeded.	8	5758
Sep 9, 2026 @ 11:39:05.732	ubuntu-victim	syslog: User missed the password more than o...	10	2502
Sep 9, 2026 @ 11:39:05.730	ubuntu-victim	syslog: User authentication failure.	5	2501
Sep 9, 2026 @ 11:39:05.718	ubuntu-victim	Maximum authentication attempts exceeded.	8	5758
Sep 9, 2026 @ 11:39:03.766	ubuntu-victim	sshd: authentication failed.	5	5760
Sep 9, 2026 @ 11:39:03.761	ubuntu-victim	syslog: User missed the password more than o...	10	2502
Sep 9, 2026 @ 11:39:03.761	ubuntu-victim	syslog: User authentication failure.	5	2501
Sep 9, 2026 @ 11:39:03.756	ubuntu-victim	Maximum authentication attempts exceeded.	8	5758
Sep 9, 2026 @ 11:39:03.749	ubuntu-victim	sshd: authentication failed.	5	5760
Sep 9, 2026 @ 11:39:03.742	ubuntu-victim	sshd: authentication failed.	5	5760
Sep 9, 2026 @ 11:39:03.735	ubuntu-victim	unix_chkpwd: Password check failed.	5	5557
Sep 9, 2026 @ 11:39:03.727	ubuntu-victim	unix_chkpwd: Password check failed.	5	5557
Sep 9, 2026 @ 11:39:03.727	ubuntu-victim	unix_chkpwd: Password check failed.	5	5557
Sep 9, 2026 @ 11:39:01.781	ubuntu-victim	sshd: authentication failed.	5	5760
Sep 9, 2026 @ 11:39:01.759	ubuntu-victim	sshd: authentication failed.	5	5760

Figure 5: 310 correlated events generated by the attack, including the escalated Rule 40111 “Multiple authentication failures” alert.

5. Rule Analysis

Inspecting Rule 40111 revealed the exact logic behind the detection, along with the framework it was pre mapped to:

Condition Field	Value	Meaning
Frequency	12	Rule fires once 12 matching events occur
Timeframe	160 seconds	All 12+ events must occur within this window
if_matched_group	authentication_failed	Only counts events already tagged as auth failures
same_source_ip	true	All failures must originate from one IP address

In plain terms: 12 or more failed logins from the same source IP within 160 seconds are treated as a brute force pattern and escalated automatically, exactly the condition my Hydra attack satisfied.

Multiple authentication failures.			
Information ID 40111 Level 10 File 0280-attack_rules.xml Path ruleset/rules			
Groups authentication_failures, syslog, attacks			
Details Frequency 12 Timeframe 160 If_matched_group authentication_failed Same_source_ip true			
Compliance PCI DSS 10.2.4, 10.2.5 GPG 13 7.1, 7.8 GDPR IV_35.7.d, IV_32.2 HIPAA 164.312.b			
NIST-800-53 AU.14, AC.7 TSC CC6.1, CC6.8, CC7.2, CC7.3 MITRE Techniques Brute Force MITRE Tactics Credential Access			

Figure 6: Rule 40111 detail: detection logic, MITRE ATT&CK technique, and multi framework compliance mapping.

MITRE ATT&CK & Compliance Mapping

A key strength of this detection is that it is not just technically sound, it is pre mapped to industry frameworks, meaning the same alert has both security and regulatory relevance:

Framework	Control Reference
MITRE ATT&CK	T1110, Brute Force (Credential Access)
PCI DSS	10.2.4, 10.2.5
GDPR	IV 35.7.d, IV 32.2
HIPAA	164.312.b
NIST 800-53	AU.14, AC.7
TSC (SOC 2)	CC6.1, CC6.8, CC7.2, CC7.3

Results

- Confirmed a fully functional, cloud integrated SIEM pipeline: victim VM → Wazuh agent → cloud manager → indexed, searchable, correlated alerts.
- Validated detection at two distinct severity tiers: individual auth failures (level 5) and correlated brute force patterns (level 10).
- Confirmed automatic MITRE ATT&CK technique tagging (T1110, Brute Force, Credential Access tactic).
- Confirmed the same alert maps to PCI DSS, GDPR, HIPAA, NIST 800-53, and SOC 2 (TSC) controls, demonstrating my awareness of how technical detections tie into compliance reporting.
- Diagnosed and resolved real infrastructure issues along the way, including a stale process lock file preventing the Wazuh agent from restarting cleanly, a realistic troubleshooting scenario for a junior SOC/IT role.

Skills Demonstrated

- SIEM deployment and administration (Wazuh: manager, agent, dashboard, rule inspection)
- Virtualization and network isolation (VirtualBox, NAT networking, VM to VM segmentation)
- Linux system administration and troubleshooting (systemd, journalctl, log analysis, service recovery)
- Offensive tooling for defensive validation (Hydra, credential brute force simulation)
- Log source correlation across sshd, PAM, and syslog
- MITRE ATT&CK framework mapping
- Regulatory compliance awareness (PCI DSS, GDPR, HIPAA, NIST 800-53, SOC 2)
- Cloud infrastructure basics (VPS provisioning, firewall configuration, remote service management)